

Veille RGD

Analyse de conformité et recommandations — Application de productivité gamifiée

RÉGLEMENTATION

RGPD (UE) 2016/679

HÉBERGEMENT

Hors Union Européenne

MISE EN PRODUCTION

Prévue

RISQUE GLOBAL

⚠ **Élevé**

01 Contexte et périmètre

Flowly est une application de productivité gamifiée destinée à une mise en production réelle, collectant des données personnelles sensibles (activité applicative, temps de travail, comportements de navigation) sur des utilisateurs potentiellement mineurs. L'hébergement hors Union Européenne rend cette application directement soumise aux obligations de transfert international du RGPD.

Ce document identifie les obligations légales applicables, les risques de non-conformité et les mesures concrètes à mettre en place avant tout déploiement.

02 Cartographie des données collectées

Le RGPD impose de savoir exactement quelles données sont collectées, pourquoi, et pendant combien de temps. Voici la cartographie pour Flowly :

Catégorie	Données	Base légale	Durée de conservation	Risque
Compte utilisateur	Nom, email, avatar, mot de passe hashé	Exécution du contrat	Durée du compte + 3 ans	Modéré
Activité applicative	Apps ouvertes, durée d'utilisation, sites visités	Consentement explicite	12 mois glissants	Élevé
Comportement clavier/souris	Indicateurs d'activité (pas de frappes brutes)	Consentement explicite	12 mois glissants	Élevé
Sessions de focus	Horodatage, durée, points gagnés	Exécution du contrat	24 mois	Modéré
Profil social	Avatar, décorations, monde 3D, classement	Exécution du contrat	Durée du compte	Faible
Données OAuth	Token d'accès Google / GitHub / LinkedIn	Consentement	Durée de la session	Modéré
Données de mineurs	Toutes les données ci-dessus si utilisateur < 15 ans	Consentement parental requis	Identique + purge à 18 ans	Critique

03 Transfert de données hors Union Européenne

POINT CRITIQUE
Héberger des données personnelles de résidents européens sur des serveurs hors UE est soumis au Chapitre V du RGPD. Sans mécanisme de transfert valide, cette pratique est illégale et expose l'entreprise à des amendes pouvant atteindre **20 millions d'euros ou 4% du chiffre d'affaires mondial**.

Selon la destination des serveurs, les mécanismes de transfert valides disponibles sont :

Mécanisme	Applicable si...	Complexité
Décision d'adéquation	Serveurs aux États-Unis (Data Privacy Framework), Japon, Canada, Suisse...	Faible – automatisatique
Clauses Contractuelles Types (CCT)	Tout pays tiers, accord signé avec l'hébergeur	Moyenne
Règles d'entreprise contraignantes (BCR)	Groupes multinationaux uniquement	Élevée – non applicable ici
Consentement explicite	Transfert occasionnel, utilisateur informé du risque	Moyenne – fragile

RECOMMANDATION FLOWLY
Si l'hébergeur est AWS, GCP ou Azure (même hors UE), ces fournisseurs proposent des **CCT pré-signées** et participent au Data Privacy Framework pour leurs entités américaines. Vérifier que le contrat avec l'hébergeur inclut les CCT version 2021 de la Commission Européenne. À défaut, migrer vers une région EU de l'hébergeur est la solution la plus simple.

04 Données de mineurs — Obligations renforcées

RISQUE CRITIQUE
En France, le seuil de minorité numérique est fixé à **15 ans** (Article 7-1 de la loi Informatique et Libertés). En dessous de cet âge, le traitement de données est conditionné au **consentement conjoint du mineur et de son représentant légal**. Les fonctionnalités de groupe/organisations rendent ce cas très probable dans Flowly.

OBLIGATIONS LÉGALES - Vérification de l'âge à l'inscription - Consentement parental collecté et archivé - Interface adaptée aux mineurs (langage clair) - Pas de profilage publicitaire sur les mineurs - Pas de dark patterns pour pousser à la consommation (boutique virtuelle) - Droit à l'effacement facilité	MESURES TECHNIQUES RECOMMANDÉES - Champ de date de naissance obligatoire à l'inscription - Flux d'inscription séparé si âge < 15 ans - Email de confirmation envoyé au parent - Désactivation de la boutique réelle pour les mineurs - Restriction de visibilité du profil (monde non public) - Suppression automatique à la demande parentale
ATTENTION — BOUTIQUE RÉELLE La fonctionnalité d'échange de points contre des coupons et codes promo réels constitue une relation commerciale. Elle est soumise au droit de la consommation en plus du RGPD. Les mineurs ne peuvent pas contracter sans autorisation parentale — cette feature doit être intégralement désactivée pour les comptes mineurs.	

05 Bases légales et consentement

Chaque traitement de données doit reposer sur une base légale identifiée parmi les six prévues par l'Article 6 du RGPD. Pour Flowly :

POINT DE VIGILANCE — MONITORING D'ACTIVITÉ
La collecte des **applications ouvertes, sites visités et indicateurs clavier/souris** ne peut reposer que sur le **consentement explicite** (Article 6.1.a). Ce consentement doit être libre, éclairé, spécifique et révoquable à tout moment. Un simple "J'accepte les CGU" ne suffit pas — il faut un consentement granulaire, distinct pour chaque type de collecte.

- Le consentement doit être :
- Granulaire** : l'utilisateur peut accepter le suivi des apps sans accepter le suivi clavier, par exemple.
 - Révocable facilement** : un bouton accessible dans les paramètres, pas enfoui dans les CGU.
 - Sans nudge** : le refus ne doit pas dégrader l'expérience principale de l'app (pas de perte de points si l'utilisateur refuse le tracking fin).
 - Archivé** : la date et le contenu du consentement doivent être conservés comme preuve.

06 Droits des utilisateurs — Obligations d'implémentation

Le RGPD confère aux utilisateurs des droits que l'application doit permettre d'exercer **dans un délai d'un mois** (Article 12).

Droit	Description	Implémentation Flowly
Accès (Art. 15)	L'utilisateur peut obtenir une copie de toutes ses données	Export JSON/CSV depuis les paramètres du compte
Rectification (Art. 16)	Correction des données inexacts	Édition du profil dans l'app
Effacement (Art. 17)	Suppression du compte et de toutes les données	Bouton "Supprimer mon compte" + purge effective sous 30 jours
Portabilité (Art. 20)	Récupérer ses données dans un format lisible	Export JSON structuré (sessions, points, historique)
Opposition (Art. 21)	S'opposer à certains traitements	Toggle de désactivation du monitoring dans les paramètres
Limitation (Art. 18)	Geler un traitement sans suppression	Suspension du compte sans perte de données

07 Sécurité des données (Article 32)

Le RGPD impose des mesures de sécurité **appropriées au risque**. Compte tenu de la nature des données collectées (activité applicative, données de mineurs), le niveau de risque est élevé.

MESURES OBLIGATOIRES - Chiffrement des données en transit (TLS 1.2+) - Chiffrement des données au repos (AES-256) - Hashage des mots de passe (bcrypt / Argon2) - Tokens stockés dans Keychain (iOS) / EncryptedSharedPreferences (Android) - Authentification multi-facteurs pour les admins - Journaux d'accès aux données (logs)	MESURES RECOMMANDÉES - Pseudonymisation des données d'activité (ID anonyme) - Politique de rétention automatique (purge des données expirées) - Tests de pénétration avant mise en production - Limitation des accès en base (principe du moindre privilège) - Séparation des environnements dev / prod - Pas de données personnelles dans les logs applicatifs
VIOLATION DE DONNÉES — ARTICLE 33 En cas de fuite ou de violation de données, Flowly doit notifier la CNIL dans les 72 heures . Si la violation présente un risque élevé pour les personnes concernées (données d'activité, mineurs), les utilisateurs impactés doivent également être informés individuellement (Article 34). Un plan de réponse aux incidents doit être préparé avant la mise en production.	

08 Analyse d'Impact (AIPD — Article 35)

OBLIGATOIRE POUR FLOWLY
Une **Analyse d'Impact relative à la Protection des Données (AIPD)** est obligatoire avant la mise en production. Flowly cumule plusieurs critères déclencheurs : surveillance systématique du comportement (apps, clavier, sites), **traitement de données de mineurs**, et **traitement à grande échelle**.

- L'AIPD doit documenter :
- La description systématique des traitements et leurs finalités
 - L'évaluation de la nécessité et de la proportionnalité de chaque traitement
 - L'évaluation des risques pour les droits et libertés des personnes
 - Les mesures envisagées pour faire face aux risques

RESSOURCE
La CNIL met à disposition l'outil **PIA (Privacy Impact Assessment)** en open source pour réaliser l'AIPD : cnil.fr/fr/pia-logiciel

09 Documents légaux à produire

- ☐ **Politique de confidentialité** — Accessible avant toute inscription, rédigée en langage clair, détaillant toutes les données collectées, leurs finalités, durées de conservation et droits des utilisateurs. Obligatoire sur App Store et Google Play.
- ☐ **CGU / CGV** — Conditions générales d'utilisation incluant les règles de la boutique virtuelle et réelle, les streaks, et les mécaniques de gamification. Les CGV s'appliquent dès qu'il y a échange de valeur réelle (coupons).
- ☐ **Politique de cookies** — Si Flowly Web utilise des cookies ou traceurs (analytics, publicité). Bandeau de consentement conforme requis.
- ☐ **Registre des traitements (Article 30)** — Document interne listant tous les traitements de données, leurs bases légales, sous-traitants et durées. Obligatoire pour toute organisation traitant des données à grande échelle.
- ☐ **DPA (Data Processing Agreement)** — Contrat à signer avec chaque sous-traitant accédant aux données (hébergeur, Supabase, services) — analytics, prestataire email...).
- ☐ **Formulaire de consentement parental** — À implémenter dans le flux d'inscription pour les utilisateurs déclarant moins de 15 ans.
- ☐ **AIPD** — Analyse d'Impact à réaliser et documenter avant mise en production.

10 Synthèse des risques et priorités

Risque	Niveau	Action requise	Priorité
Hébergement hors UE sans mécanisme valide	Critique	Signer CCT avec l'hébergeur ou migrer en EU	Avant lancement
Données de mineurs sans consentement parental	Critique	Flux d'inscription dédié + vérification d'âge	Avant lancement
Monitoring applicatif sans consentement granulaire	Élevé	Écran de consentement détaillé au premier lancement	Avant lancement
Absence d'AIPD	Élevé	Réaliser l'AIPD via l'outil PIA CNIL	Avant lancement
Pas de politique de confidentialité	Modéré	Rédiger et intégrer dans l'app + stores	Phase beta
Boutique réelle accessible aux mineurs	Modéré	Désactivation conditionnelle selon l'âge déclaré	Phase beta
Absence de procédure violation de données	Modéré	Rédiger un plan de réponse aux incidents	Post-lancement
Pas de DPA signé avec les sous-traitants	Modéré	Identifier tous les sous-traitants et signer les DPA	Post-lancement